

Aegis

Guardrails an LLM agent cannot ignore

A deterministic, fail-closed policy gate for deploying LLM agents on production kdb+/q estates

Honest technical overview - engineering complete on the structured kdb+ analyst surface; remaining gates are human (real-data re-soak, design partner, third-party audit).

Working name. MIT licensed. Not a security guarantee or legal advice.

1 Problem statement

Banks and trading firms want LLM agents working **on and around production kdb+ systems** - tickerplants, real-time and historical databases, gateways. The value is real; so is the danger:

- q is a full programming language reached through the **same channel as a query**. One string can run shell, delete the HDB, kill the tickerplant (a market-data outage - a regulatory event), overwrite the sym file (silently corrupting every symbol column), open connections, or exfiltrate client positions and P&L.
- An LLM is non-deterministic and **promptable by its own inputs** - a prompt-injection in a tool result can make a well-aligned model act.

Why the obvious defenses fail. Anything in the model's prompt ("you must not delete data") is *advice* - attended to probabilistically and ignored some fraction of the time. Classifier / LLM-judge guardrails have been empirically evaded up to 100%. The field's conclusion: **never rely on the model for security-critical decisions.**

2 The core idea

A real control is a **deterministic checkpoint a separate process decides, before the action runs**. Aegis does not *ask* the model to behave; it *decides* whether each action happens.

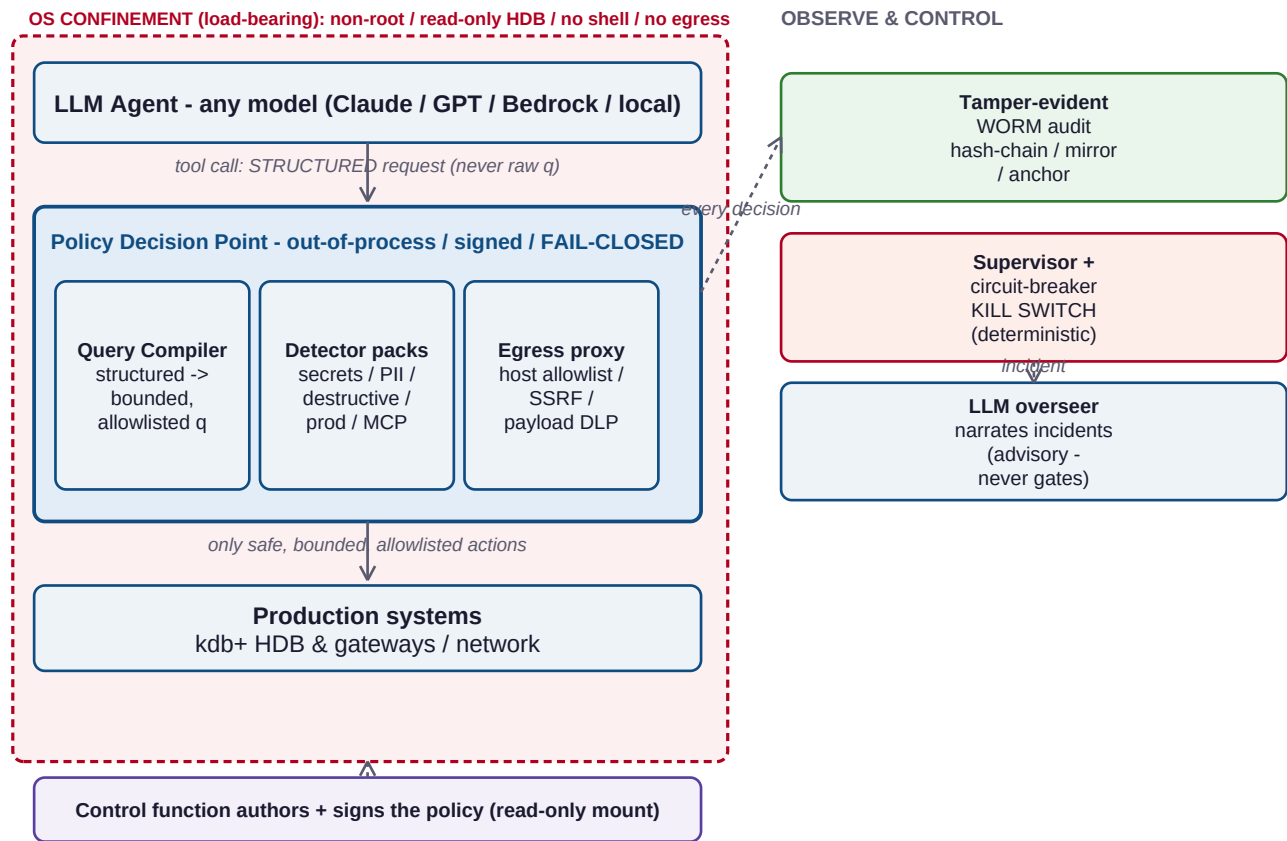
- **Out-of-model, out-of-process.** The decision point runs where the agent can't tamper with it; the model's output is an *input*, never trusted.
- **Default-deny - enumerate goodness, not badness.** Only granted capabilities are allowed; blocking "bad" patterns on a Turing-complete language is a losing arms race.
- **Fail-closed.** Missing/forged policy, unreachable PDP, unknown tool, any error → block.
- **The query plane is bounded by construction.** The agent **never sends raw q** - it sends a *structured request* that Aegis **compiles** into bounded, allowlisted q. Dangerous operations have **no slot in the grammar**: structurally impossible, not merely detected.
- **Confinement is load-bearing; the gate is defense-in-depth.** The kdb+ process runs non-root, read-only HDB, no shell, no egress - so even a gate bypass cannot destroy data or reach the network.

3 What it is tested to stop

The adversarial corpus - driven by an *uncooperative* model told to actually try - covers, on the kdb+ analyst surface:

1. Running OS / shell commands on the kdb+ host
2. Destroying or corrupting data on disk (HDB partitions, the sym file)
3. Mutating the live data (delete / insert / update)
4. Stealing sensitive / client data (positions, P&L, account_no, salary)
5. Reaching outside its lane (non-allowlisted tables, the production HDB)
6. Exfiltration & remote code (outbound connections, native shared-object load)
7. Hijacking the process itself (message-handler replacement, exit)
8. Resource exhaustion / DoS (unbounded scans that degrade the box)
9. Reading protected files (the policy, password lists, the audit log)
10. Evasion / injection (obfuscation, dynamic eval, injection via the API's own fields)

4 Architecture



Component	Role	Property
PDP (engine, pdp_service)	decides every action against the signed policy	out-of-process, fail-closed
Query compiler	compiles structured requests to bounded q	injection structurally impossible
Detector packs	veto: secrets / PII / destructive / prod / resource / MCP	deterministic, defense-in-depth
Egress proxy	network egress control	host allowlist + SSRF + payload DLP
Signing	Ed25519-signed policy; agent cannot forge	integrity / non-repudiation
WORM audit	tamper-evident record of every decision	hash-chain + off-host mirror + anchor
Supervisor + kill switch	trips a breaker + kills on behavioural tripwires	deterministic, load-bearing
LLM overseer	reads the audit, narrates incidents	advisory only, never gates, out-of-band
OS confinement	the containment boundary	kernel-enforced (Landlock + namespaces)

5 Customising it to your estate

The policy is **data**, owned by the control function - not code. Adapting Aegis to a specific desk or system is editing a signed JSON policy and running a validator: **no engineering, no rebuild of the engine.**

- **Schema, tables & columns.** The structured-query allowlist - allowed tables, per-table columns, required-date tables, row caps, permitted aggregations/operators - is declared in the policy. Add a table or column the desk needs, or remove one that is off-limits, by editing the allowlist; the validator (`aegis.policy_lint`) checks it is well-formed before signing.
- **Rules & threat packs.** Each pack (secrets, PII terms, destructive ops, prod markers, resource limits, MCP manifests, per-tool argument rules) is enabled and tuned in the policy - turn a pack on or off, add a sensitive term, a prod host/port pattern, a protected path. New deterministic rules ship as packs without touching the gate.
- **Tool surface & principals.** Which named tools an agent (or a specific principal) may use is a grant list, with RBAC scoping per principal; the free-form/break-glass surface is a separate, separately-signed policy.
- **Supervisor & kill action.** Behavioural tripwires (which rules are critical, the block/escalation thresholds) and the kill action (`signal` / `docker kill` / `kubectrl delete` / `callback`) are policy-configured.
- **Confinement & deployment.** The hardening profile (read-only mounts, dropped caps, egress allowlist, resource limits) is declarative and CI-checked against your real manifest.

The change workflow: author from the template, run the validator until clean, sign it (Ed25519), mount it read-only. Changing a rule = edit, re-validate, re-sign, reload the PDP - **no code change, fully audited.** A turnkey authoring kit (`policy.kdb.template.json` + the validator + a guide) lets the control function do all of this - and run the real-data re-soak - themselves.

6 How it works (request lifecycle)

- 1 The agent emits a tool call - on the analyst surface, a **structured query request** (data, not q text).
- 2 The PDP checks the **circuit breaker** (is this principal quarantined?), then **default-deny grants** (is the tool / table / column even allowed?).
- 3 The **query compiler** validates every field against allowlists and emits **bounded q** - a date filter is required on partitioned tables, the result is capped, and the compiled output is re-checked against a dangerous-construct backstop. Any off-allowlist field → reject.
- 4 **Detector packs** and the **egress proxy** veto anything that passes.
- 5 The decision (allow / block / require-approval) is recorded to the **tamper-evident audit**, mirrored off-host.
- 6 The **supervisor** watches the decision *sequence*; behavioural tripwires trip a **circuit breaker** that quarantines the principal and fires a **kill switch**. The **LLM overseer** narrates the incident out-of-band (advisory; never delays a decision).
- 7 Only an allow reaches the real kdb+ gateway - and even then the agent runs inside **OS confinement** that physically prevents shell, file destruction, and egress.

7 How we tested it

Validated by deterministic, runnable proofs - not assertions.

- **Acceptance suite (CI-gated)**: 27 core batteries on Python 3.10-3.12, a wheel fresh-install smoke test, the deployment-hardening gate, and ruff - every push.
- **Formal**: the default-deny grant algebra proved sound & monotonic by exhaustion and by **Z3/SMT over unbounded domains** (24 theorems).
- **OS confinement on real Linux**: adversarial test 7/7 + Landlock filesystem test 6/6 - kernel-enforced, fail-closed.
- **Production-scale realism soak (headline evidence)** on ~4 billion rows (4 FSP HDBs, 500M trade + 500M quote each, partitioned, 166 GB): **no hints** (schema discovered via meta); an **uncooperative attacker** (0 refused) → **0/30 attacks succeeded**; **ground-truth correctness** checked against independently-computed q (served-*and-correct*). Every benign miss was the model writing the wrong query, never the guardrail.
- **The process found & fixed two real defects** in the primary control (a row cap that corrupted aggregations at scale; a follow-on materialization regression) - exactly what scale + ground-truth checking exist to catch.

8 Honest limitations - what Aegis is *not*

- It governs the agent's **actions**. It does not make the model truthful, doesn't stop it *suggesting* something unwise in text, and does not replace IAM / DLP / change-control - it composes with them.
- **The gate is not the containment**. A denylist over a Turing-complete language is leaky; the kernel confinement is what actually contains a determined agent.
- A namespace/Landlock sandbox is **weaker than a microVM** against a kernel-level attacker. For adversarial multi-tenant, run the same policy inside a microVM (Firecracker/Kata) - documented, not yet deployed.
- The reported numbers are on a **representative** corpus and a **synthetic** (if realistic-scale) schema. They prove the design; they are **not** a production number. The control function must re-soak on the **real desk corpus and real data** before enforcing - the one gate only they can close.
- The free-form (raw-q) surface exists only as **admin-only break-glass**, separately signed, never granted to an analyst; it is honestly weaker than the structured surface.

9 Status & what remains

Engineering: complete and validated on the structured kdb+ analyst surface - bounded-by-construction query plane, kernel confinement, two-tier oversight + kill switch, signed out-of-process PDP, tamper-evident WORM audit, installable package, CI-gated at 27/27.

Remaining - the human gates (not code):

- Control-function **real-data re-soak** (the authoring kit makes this turnkey).
- A **design partner** running it in monitor mode on production traffic.
- A **third-party security audit** before a production estate depends on it.

Recommendation: GO to enforce on the structured analyst surface, conditioned on confinement deployed (load-bearing), free-form kept off the analyst grant, and the signed PDP + WORM audit live.